SafePay Guard

Hệ thống xác minh và phê duyệt lệnh chuyển tiền chống giả mạo (deepfake, BEC) cho doanh nghiệp vừa và nhỏ

Đồ án cuối kỳ · Bảo mật mạng máy tính và hệ thống · Hướng 1 – Security

Nhóm: …… · GVHD: ……

Bài toán: tiền bị chuyển vì yêu cầu "trông có vẻ thật"

2,9 tỷ USD

thiệt hại do lừa đảo email doanh nghiệp (BEC) tại Mỹ năm 2023

FBI IC3, Internet Crime Report 2023

25 triệu USD

một nhân viên Arup (Hồng Kông) chuyển đi sau cuộc họp video toàn người deepfake

CNN, 02/2024

Zalo · video

thủ đoạn giả danh lãnh đạo yêu cầu kế toán chuyển tiền gấp tại Việt Nam

Cảnh báo của cơ quan công an

Điểm yếu chung: quy trình tin vào giọng nói, khuôn mặt, địa chỉ email, chữ ký trên văn bản – tất cả đều làm giả được với chi phí ngày càng thấp.

Câu hỏi của đồ án: hệ thống dựa vào đâu để tin, kiểm chứng hoặc từ chối một yêu cầu chuyển tiền?

Ai dùng hệ thống, ai tấn công

Doanh nghiệp 20–200 nhân sự, chuyển tiền cho nhà cung cấp qua Internet Banking hằng tuần

1

Kế toán viên

Lập lệnh, tiếp nhận yêu cầu đổi STK. Không được duyệt.

2

Kế toán trưởng

Duyệt lệnh, gọi lại xác minh, duyệt đổi STK.

3

Giám đốc / Phó GĐ

Bắt buộc với lệnh ≥ 500 triệu hoặc rủi ro cao.

4

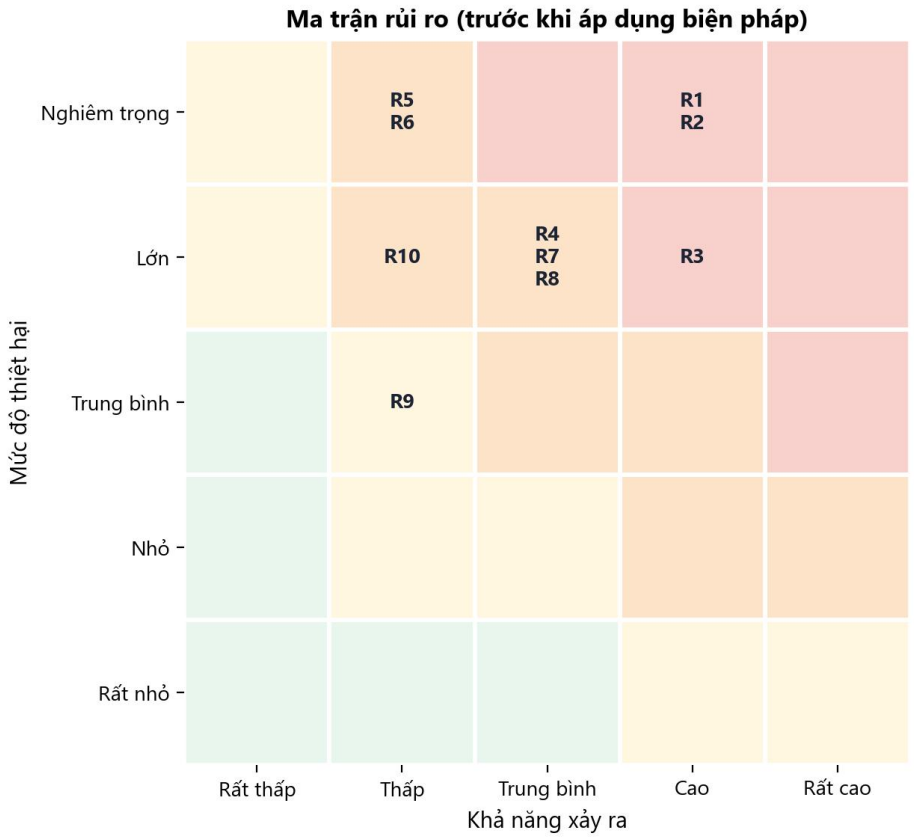
Quản trị IT

Duyệt thiết bị mới, khoá khẩn cấp. Không có quyền nghiệp vụ.

Tác nhân đe dọa

- **Nhóm lừa đảo BEC:** email tên miền na ná, chiếm hộp thư NCC, giả giọng/video lãnh đạo
- **Kẻ chiếm tài khoản:** trang đăng nhập giả lấy mật khẩu + OTP, đánh cắp cookie
- **Mã độc máy trạm:** tráo số tiền / STK hiển thị trên trình duyệt
- **Nội gián:** tự lập – tự duyệt, sửa CSDL, xoá nhật ký
- **Kẻ trộm thiết bị:** lấy điện thoại của người duyệt

Tài sản cần bảo vệ và rủi ro chính



Mã	Rủi ro	KN	TH	Điểm
R1	Giả danh lãnh đạo (deepfake/giả giọng)	4	5	20
R2	Email giả NCC đổi số tài khoản (BEC)	4	5	20
R3	Lộ mật khẩu / phishing lấy OTP	4	4	16
R4	Đánh cắp phiên đăng nhập	3	4	12
R5	Mã độc tráo nội dung khi duyệt	2	5	10
R6	Nội gián sửa dữ liệu trong CSDL	2	5	10
R7	Người tạo lệnh tự duyệt / thông đồng	3	4	12
R8	Mất / bị chiếm điện thoại người duyệt	3	4	12
R9	Phát lại chữ ký / OTP	2	3	6
R10	Xoá / sửa nhật ký để che dấu vết	2	4	8

Tài sản:

- Tiền trong tài khoản doanh nghiệp
- Sổ đăng ký nhà cung cấp (STK, SĐT đã xác minh)
- Nội dung lệnh: người nhận, STK, số tiền
- Mật khẩu, bí mật OTP, khoá riêng thiết bị
- Khoá HMAC máy chủ, phiên đăng nhập
- Danh bạ nội bộ, nhật ký kiểm toán

Không cố phát hiện deepfake – làm cho deepfake vô dụng

Mọi thông tin từ bên ngoài chỉ là lời khẳng định chưa được xác minh

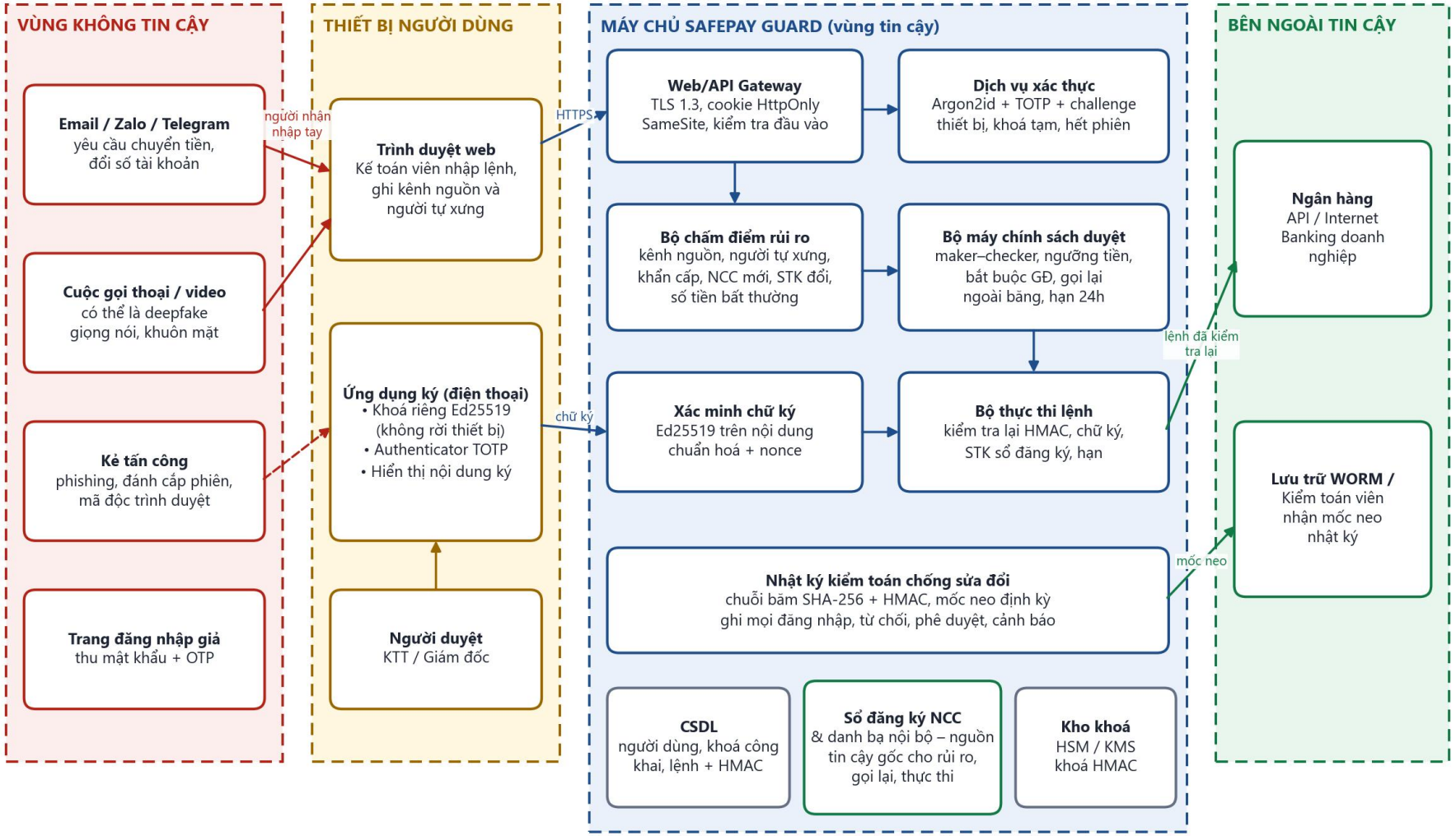
✓ HỆ THỐNG TIN

- Chữ ký Ed25519 từ thiết bị đã đăng ký, khớp đúng nội dung lệnh
- Sổ đăng ký NCC & danh bạ nội bộ (lập khi ký hợp đồng / nhận việc)
- Kết quả gọi lại tới số lấy từ sổ đăng ký
- Dữ liệu lệnh – sau khi kiểm tra lại HMAC và chữ ký

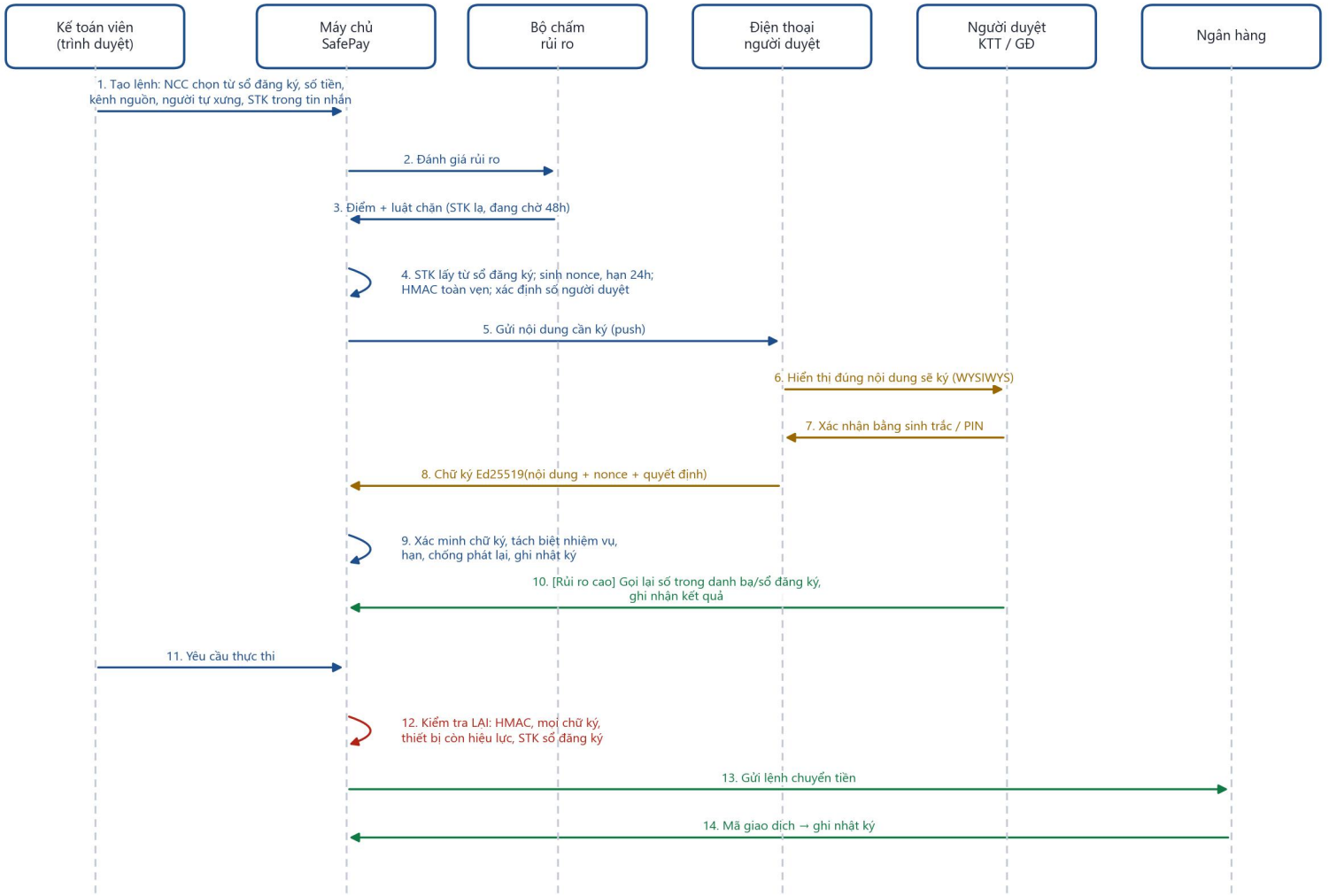
✗ HỆ THỐNG KHÔNG TIN

- Giọng nói, khuôn mặt trong cuộc gọi thoại / video
- Email, tin nhắn, văn bản scan, hoá đơn ảnh
- STK / số điện thoại do người yêu cầu cung cấp
- Lời tự xưng “tôi là Giám đốc”, dữ liệu trình duyệt gửi lên

Kiến trúc và ranh giới tin cậy



Luồng tạo – duyệt – thực thi một lệnh



1 **STK lấy từ sổ đăng ký**

Không bao giờ lấy từ tin nhắn. STK lạ trong tin nhắn → chặn ngay.

2 **Ký trên điện thoại**

Người duyệt thấy đúng nội dung sẽ ký; chữ ký phủ cả nonce và quyết định.

3 **Kiểm tra lại khi thực thi**

Không tin trạng thái APPROVED trong CSDL: HMAC, mọi chữ ký, thiết bị, STK.

Sáu cơ chế bảo vệ chính

1 MFA gắn thiết bị

Argon2id + TOTP chống phát lại + thiết bị ký challenge. Thiết bị mới cần admin duyệt.

2 Chữ ký giao dịch

Ed25519 trên JSON chuẩn hoá: nội dung, nonce, hạn, quyết định. Không ký được → không duyệt được.

3 Phê duyệt theo rủi ro

≥ 50tr: 2 người; ≥ 500tr hoặc rủi ro cao: có GĐ. Người tự xưng phải tự ký.

4 Gọi lại ngoài băng

Chỉ chấp nhận số trong danh bạ / sổ đăng ký. Bị phủ nhận → REJECTED + cảnh báo.

5 Sổ đăng ký + 48h chờ

Không có ô nhập STK tự do. Đổi STK: gọi lại, ký duyệt, chờ 48h, +30 điểm 30 ngày.

6 Toàn vẹn & nhật ký

HMAC trên lệnh (khoá trong HSM). Nhật ký chuỗi băm + HMAC + mốc neo bên ngoài.

Chấm điểm rủi ro: đầu vào bên ngoài chỉ làm tăng điểm

Luật	Điểm
Yêu cầu từ kênh ngoài (email, chat, ảnh, thoại, video)	+25
Tự xưng là lãnh đạo qua kênh ngoài	+20
Khẩn cấp / bí mật (“gấp”, “đừng báo ai”)	+15
Lần đầu trả cho NCC / số tiền > 3× trung bình	+20
STK NCC đổi trong 30 ngày	+30
Ngoài giờ làm việc	+10

THẤP < 30

1 người duyệt (≥ 50 triệu: 2)

TRUNG BÌNH 30–59

2 người duyệt

CAO ≥ 60

2 người + Giám đốc + gọi lại

CHẶN

STK lạ trong tin nhắn · NCC trong 48h chờ

Ví dụ: “Giám đốc” gọi điện yêu cầu trả gấp NCC mới → 25 + 20 + 15 + 20 = 80 điểm → rủi ro CAO.

Tình huống 1: “Giám đốc” gọi video yêu cầu chuyển gấp

Hình ảnh và giọng nói giống thật – hệ thống không cần biết đó là deepfake

1

Kế toán nhập lệnh 300 triệu

kênh: cuộc gọi · tự xưng: Giám đốc Nam · khẩn cấp

2

Rủi ro CAO – 80 điểm

cần 2 người + chính GĐ Nam ký + gọi lại

3

KTT và Phó GĐ đều duyệt

vẫn CHƯA ĐỦ – thiếu chữ ký của GĐ Nam

4

Gọi lại số “GĐ” đọc

bị từ chối: không phải số trong danh bạ

5

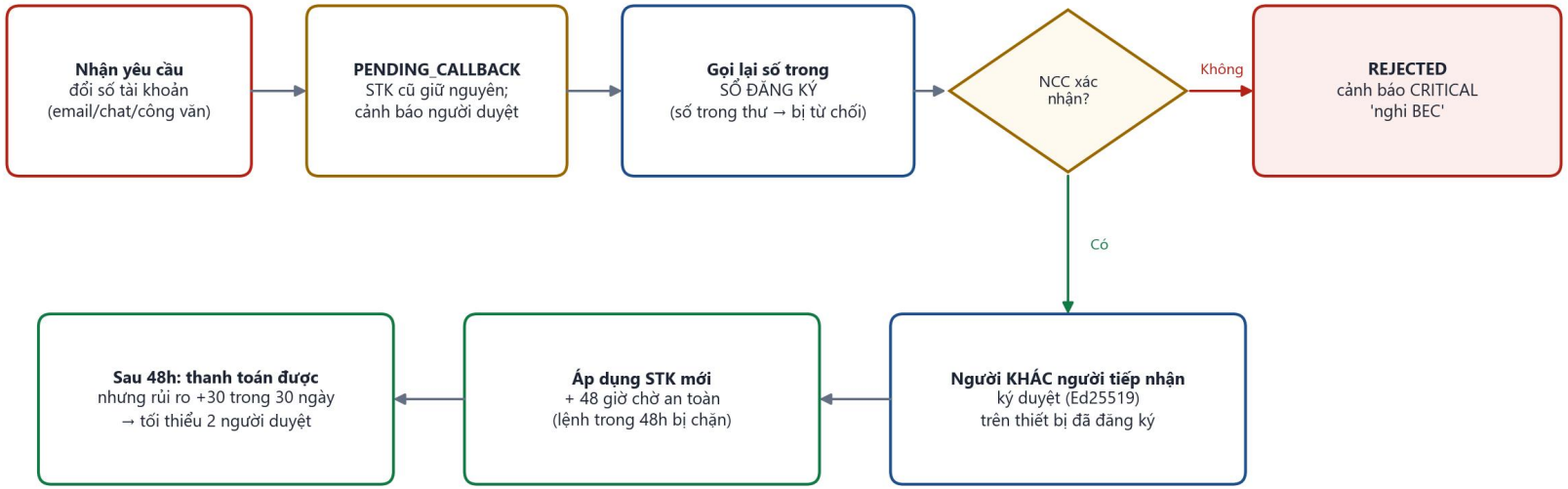
Gọi số GĐ trong danh bạ

GĐ: “Tôi không gọi” → REJECTED, cảnh báo

Biến thể: kẻ gian đọc STK mới (9704 2299 8811) → STK khác sổ đăng ký → lệnh bị CHẶN ngay khi tạo.

Nếu đó là Giám đốc thật: chỉ tốn thêm một lần bấm ký trên điện thoại của Giám đốc.

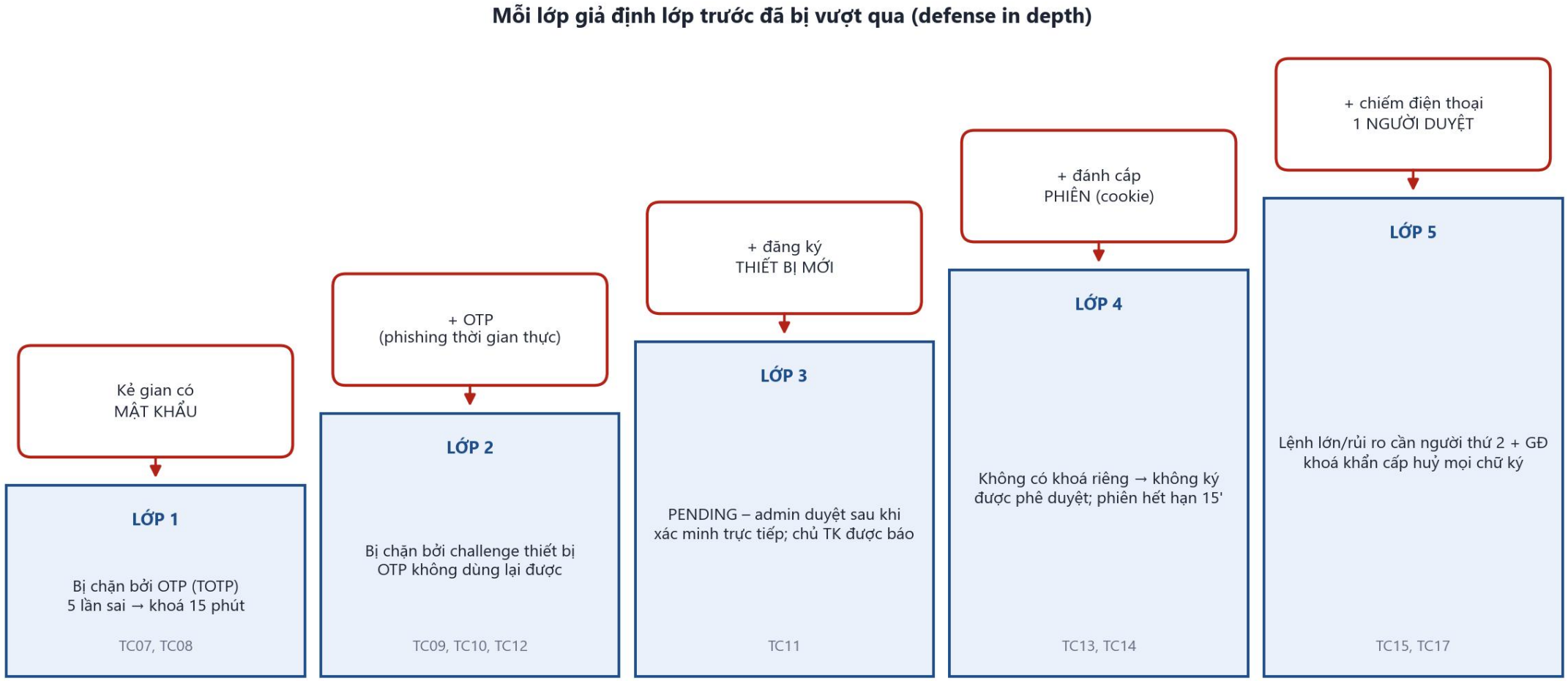
Tình huống 2: email giả nhà cung cấp đổi số tài khoản



- **Email từ minhphat-packaging.co:** *"từ tháng này chuyển vào TK ACB 88886666999, liên hệ 0912 345 678"*
- **Hệ thống:** STK cũ giữ nguyên · gọi số trong email → từ chối · gọi số trong sổ (028 3812 3456) → NCC phủ nhận → REJECTED, cảnh báo CRITICAL
- **Nếu NCC đổi thật:** vẫn đổi được, nhưng 48 giờ đầu mọi lệnh tới NCC đó bị chặn

Tình huống 3: tài khoản bị chiếm quyền

Mỗi lớp được thiết kế với giả định lớp trước đã bị vượt qua



Tình huống 4: dữ liệu bị chỉnh sửa

Mã độc tráo số tiền

Màn hình hiển thị 4,8 triệu thay vì 48 triệu → chữ ký không khớp lệnh → từ chối, cảnh báo.

TC23

Nội gián sửa CSDL

Đổi STK của lệnh đã duyệt → HMAC sai → lệnh BLOCKED khi thực thi.

TC24

Chữ ký dùng sai ngữ cảnh

Chữ ký lệnh A dùng cho lệnh B; chữ ký "từ chối" dùng làm "duyệt" → từ chối.

TC25–26

Sửa / xoá nhật ký

Sửa bản ghi, xoá bản ghi giữa, cắt đuôi → phát hiện bằng chuỗi băm, HMAC, mốc neo.

TC27

Bốn dạng đầu vào không đáng tin

Giả mạo · chỉnh sửa · đánh cắp · sử dụng sai ngữ cảnh – mỗi dạng có cơ chế riêng

Dạng	Ví dụ	Hệ thống xử lý	Kịch bản / test
Giả mạo	Deepfake video/giọng nói, email giả NCC, ảnh hoá đơn bị sửa STK, ảnh chụp màn hình "GĐ đã duyệt"	Chỉ là lời khẳng định: STK lấy từ sổ, người tự xưng phải tự ký, gọi lại số danh bạ	KB03–05, KB15
Chỉnh sửa	Tráo số tiền lúc ký, sửa CSDL sau khi duyệt, sửa/xoá nhật ký	Chữ ký phủ toàn bộ nội dung, HMAC kiểm tra lại khi thực thi, chuỗi băm + mốc neo	KB10, 11, 14
Đánh cắp	Mật khẩu, OTP, cookie phiên, điện thoại người duyệt	MFA gắn thiết bị, phê duyệt cần khoá riêng, người duyệt thứ hai, khoá khẩn cấp	KB07–09, KB13
Sai ngữ cảnh	Chữ ký của lệnh khác, chữ ký "từ chối", OTP cũ, phê duyệt quá hạn, số gọi lại của kẻ gian	Ràng buộc ngữ cảnh: request_id, nonce, quyết định, hạn trong nội dung ký; bộ đếm OTP	TC09, 18, 22, 25, 26, 30

Prototype: Python + Flask

Chạy được trên máy cá nhân, kèm 15 kịch bản demo tự động

Thành phần

- **core.py** chính sách, phê duyệt, thực thi
- **crypto.py** Argon2id, TOTP, Ed25519, HMAC
- **risk.py** bộ chấm điểm rủi ro
- **audit.py** nhật ký chuỗi băm + mốc neo
- **device.py** mô phỏng ứng dụng ký trên điện thoại
- **app.py** giao diện web + nút mô phỏng tấn công

Chạy thử

```
pip install flask cryptography argon2-cffi pytest
cd prototype
python demo_cli.py
python -m pytest -v
python app.py  →  127.0.0.1:5000
```

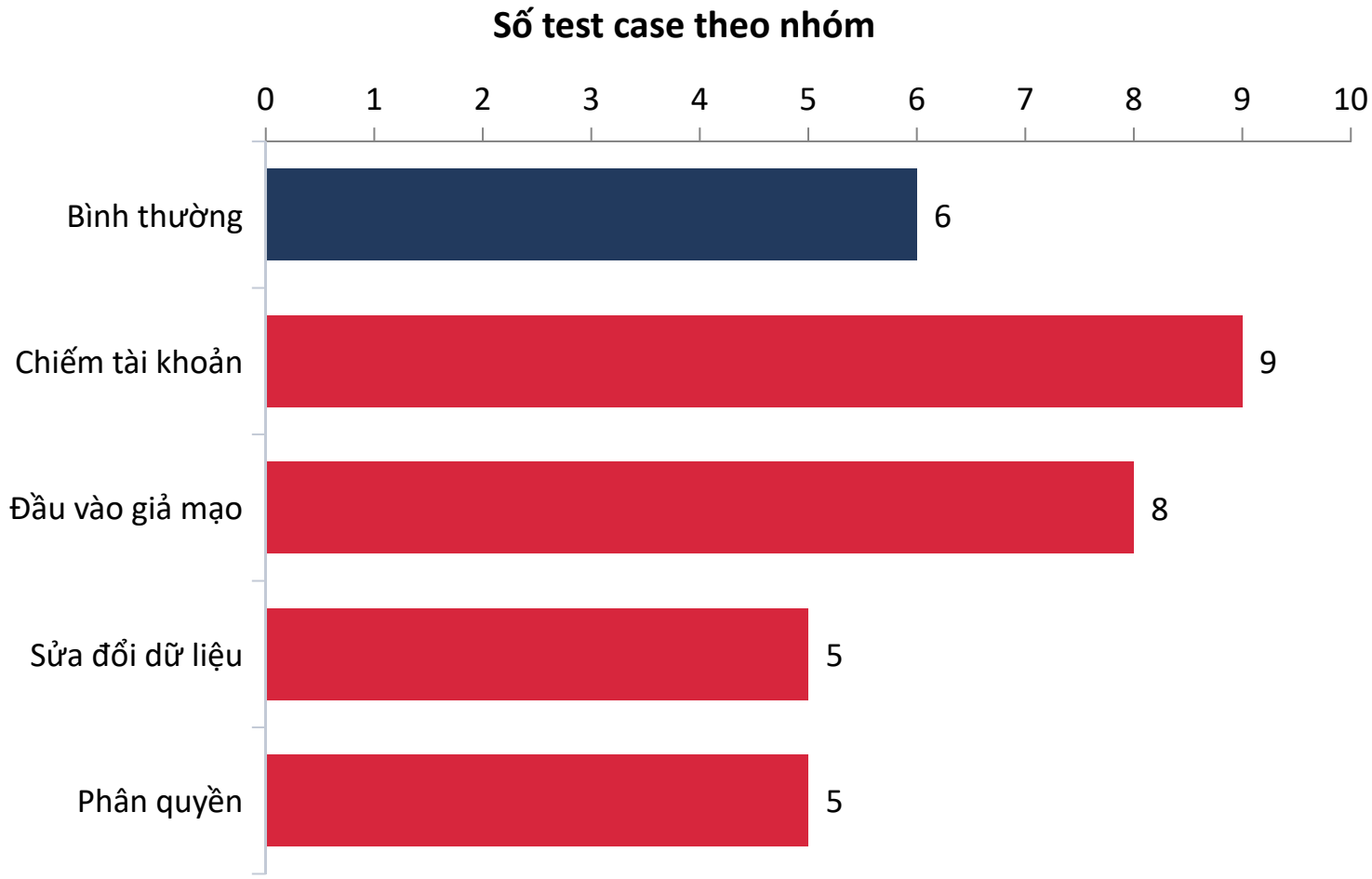
- Trang đăng nhập hiển thị OTP của từng tài khoản demo
- Màn hình “điện thoại” hiển thị đúng nội dung sẽ ký
- Trang “Kịch bản tấn công” chạy cả 15 kịch bản

Kiểm thử: 33 test case, 38/38 lượt đạt

38/38

lượt kiểm thử đạt (100%)

- 6 test luồng bình thường
- 27 test tình huống rủi ro
- Đồng hồ giả lập: hết hạn, khoá tạm, 48h chờ
- Kiểm tra đúng mã lỗi chính sách



Trade-off: an toàn có cái giá của nó

Đánh đổi	Ngắn hạn	Dài hạn	Quyết định
Duyệt nhiều lớp, gọi lại	Chậm lệnh gấp, người dùng phản ứng	Thành thói quen; nhân viên có lý do để từ chối “sếp”	Chỉ kích hoạt theo rủi ro
48 giờ chờ khi đổi STK	Có thể trễ hạn thanh toán	Chặn gần như toàn bộ BEC đổi tài khoản	Giữ; báo NCC từ khi ký HĐ
Chữ ký thiết bị	Chi phí làm app, đào tạo	Vận hành rẻ, an toàn bền vững	App điện thoại; FIDO2 cho GĐ
Luật vs AI phát hiện deepfake	Luật đơn giản, đôi khi báo nhầm	AI lỗi thời nhanh, khó giải thích	Luật quyết định; AI chỉ cộng điểm
Nhật ký đầy đủ vs riêng tư	Điều tra dễ	Kho dữ liệu dễ bị lạm dụng	Thu thập tối thiểu, có hạn lưu
Tích hợp ngân hàng	Lớp duyệt riêng + đối soát	API ngân hàng trực tiếp	Triển khai 2 giai đoạn

Hạn chế và hướng phát triển

Hạn chế

- Phụ thuộc chất lượng sổ đăng ký ban đầu
- Không chống được thông đồng của đủ số người duyệt
- Lệnh < 50 triệu chỉ cần 1 người duyệt
- Kết quả gọi lại do con người khai
- Prototype: lưu bộ nhớ, chưa HTTPS, HSM, app thật

Hướng phát triển

- App di động với passkey/FIDO2, Secure Enclave
- Xác nhận tự động trên app của người được nêu tên
- Đối chiếu hoá đơn điện tử, tên chủ tài khoản
- Học máy phát hiện bất thường (chỉ cộng điểm)
- Mốc neo nhật ký lên Object Lock / RFC 3161

Kết luận

1

Chuyển gốc rễ của niềm tin

từ thứ “trông có vẻ thật” sang chữ ký số, dữ liệu gốc đã xác minh và kênh xác minh độc lập

2

Phòng thủ nhiều lớp

giả mạo đầu vào, chiếm tài khoản, sửa dữ liệu đều có lớp chặn riêng và được kiểm thử

3

Thực tế, triển khai được

lệnh thường ngày vẫn nhanh; chi phí thấp; lộ trình 2 giai đoạn

Cảm ơn thầy/cô và các bạn đã lắng nghe – Hỏi & đáp